

International Cybersecurity and Digital Forensics Academy (ICDFA)

CTF 2: Practical Lab Submission

CIP-A105 — Offensive Security Operations II

Student Name	Lilian Wanjiku
Registration Number	EHIT/2026/16969
Cohort / Programme	Cohort 11
Submission Date	23rd September 2026
Instructor / Assessor	Abubakar Salisu

Virtual Machine Information

- **Attacker VM**
Linux Distribution: Kali GNU/Linux Rolling
Kernel: Linux 6.12.13-amd64
Hostname: kali
Username: kali
IP Address: 192.168.56.101
- **Target VM**
Name: OPFOR-02 (Operation Black Forge)
Distribution: PCLinuxOS 2011 (Unix)
IP Address: 192.168.56.103
Network Segment: 192.168.56.0/24 — Host-Only isolated lab network

Tools and Environment Used

- **Oracle VM VirtualBox** — Used to host both the attacker VM and OPFOR-02 on an isolated Host-Only network segment.
- **Kali Linux** — Operating system used to perform all offensive activity including scanning, enumeration, exploitation, and post-exploitation.
- **OPFOR-02** — Instructor-issued intentionally vulnerable Healthcare-themed target VM running PCLinuxOS 2011, Apache 2.2.17, and ProFTPD 1.3.3d.
- **nmap** — Used for host discovery, full TCP and UDP port sweeping, service version detection, and vulnerability script scanning.
- **arp-scan** — Used for ARP-based host discovery to confirm OPFOR-02's IP address.
- **gobuster** — Used for web content and directory discovery against the Apache web server using both common and medium wordlists.
- **nikto** — Used for web server vulnerability scanning and misconfiguration detection.

- **curl** — Used for HTTP header inspection, manual banner grabbing, robots.txt analysis, and web directory inspection.
- **whatweb** — Used for web technology fingerprinting.
- **searchsploit** — Used to search the local Exploit-DB database for known exploits matching identified service versions.
- **Metasploit Framework** — Used to attempt ProFTPD backdoor and Telnet IAC overflow exploitation modules.
- **hydra** — Used for dictionary-based credential attacks against the FTP service.
- **Firefox Browser** — Used to manually browse the target web application and administrative interfaces.
- **Windows Snipping Tool** — Used to capture screenshots as evidence of completed assessment tasks.

Safety Controls Used

- Both virtual machines were confirmed on the isolated Host-Only Adapter network (192.168.56.0/24) before any offensive activity commenced. No bridged adapter was active during the assessment.
- A clean baseline snapshot named CIP-A105-CTF2-CLEAN-BASELINE was taken before any reconnaissance traffic was sent to OPFOR-02.
- All offensive activity was conducted exclusively against OPFOR-02 at 192.168.56.103. No external or production system was contacted at any point.
- The attacker VM had no route to the internet or any production network during the assessment, confirmed via `ip a` and `ip route`.
- Only techniques required for evidence collection were used. No destructive actions, resource exhaustion, or uncontrolled fuzzing were deployed.
- No credentials, flags, exploitation paths, or screenshots were shared with other learners.
- The clean baseline snapshot will be restored at the conclusion of the assessment.

Executive Summary

A black-box offensive security assessment was conducted against OPFOR-02, an instructor-issued Healthcare-themed target virtual machine hosted on an isolated laboratory network. The assessment was conducted independently with no prior knowledge of the target's configuration, credentials, or vulnerabilities.

Scope and Rules of Engagement

- **Target:** OPFOR-02 — single instructor-issued virtual machine
- **Target IP:** 192.168.56.103
- **Attacker System:** ICDFA-KALI-LINUX at 192.168.56.101
- **Network:** Isolated Host-Only Adapter (192.168.56.0/24) — no internet, no bridged or production exposure

- **Assessment Type:** Black-box, unauthenticated, individual

Authorized techniques:

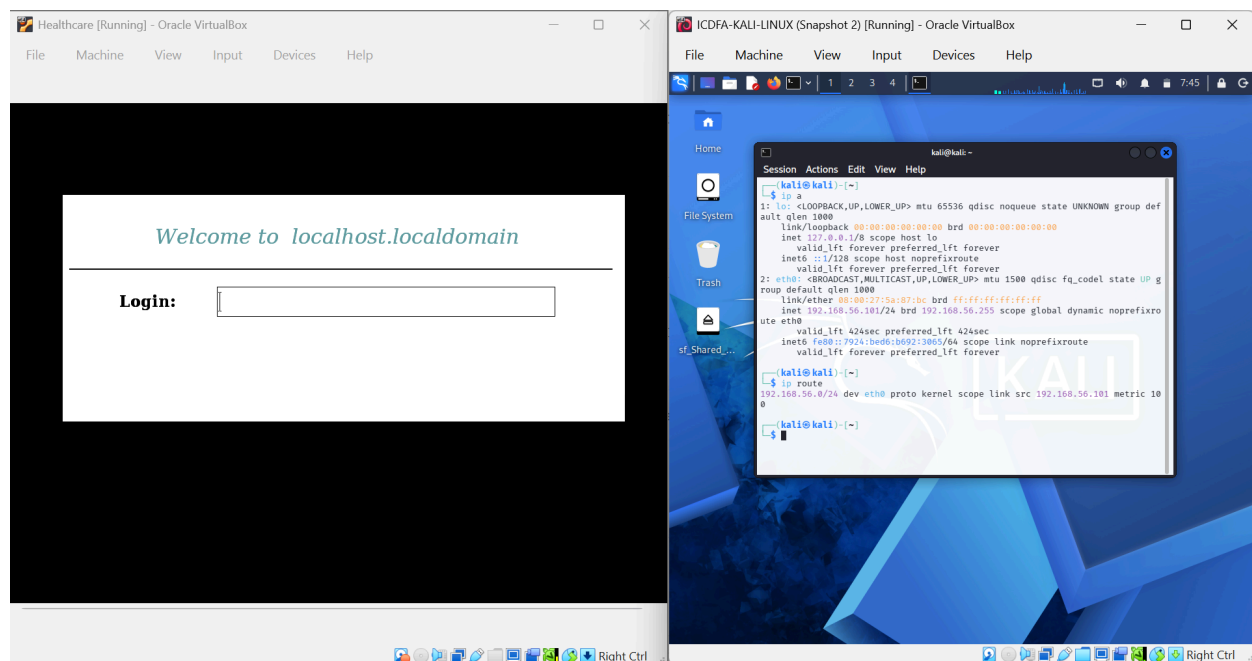
Host discovery and network reconnaissance, full TCP and UDP port scanning, service version detection and manual banner grabbing, web content enumeration and technology fingerprinting, vulnerability research and exploit validation, controlled exploitation of validated vulnerabilities against OPFOR-02 only, Linux post-exploitation enumeration and privilege escalation analysis, mission artifact recovery.

Prohibited Actions

- Any activity against external, production, or internet-connected systems. Sharing of credentials, flags, screenshots, or exploitation paths with other learners. Destructive actions, resource exhaustion, or uncontrolled fuzzing. Use of another learner's attack path or walkthrough.
- ROE compliance was maintained throughout. Both VMs were confirmed on the isolated network before any offensive activity commenced.

Reconnaissance

Host discovery was performed using two independent methods.



Enumeration

```

ICDFA-KALI-LINUX (Snapshot 2) [Running] - Oracle VirtualBox
File Machine View Input Devices Help

kali@kali: ~
Session Actions Edit View Help

kali@kali:~$ nmap -sc -v --script vuln -p 21,22,23,25,80,443,445,3306,6000,8443 -oN ~/quick_targeted.txt 192.168.56.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-22 08:25 -0400
Nmap scan report for 192.168.56.103
Host is up (0.0021s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp             ProFTPD 1.3.3d
22/tcp    closed ssh
23/tcp    closed telnet
25/tcp    closed smtp
80/tcp    open  http            Apache httpd 2.2.17 ((PCLinuxOS 2011/PREFORK-1pclos2011))
|_ http-server-header: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
|_ http-vuln-cve2011-3192:
|   VULNERABLE:
|   Apache byterange filter DoS
|   State: VULNERABLE
|   IDs: BID:49303 CVE:CVE-2011-3192
|   The Apache web server is vulnerable to a denial of service attack when numerous overlapping byte ranges are requested.
|   Disclosure date: 2011-08-19
|   References:
|   - https://www.tenable.com/plugins/nessus/55976
|   - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-3192
|   - https://www.securityfocus.com/bid/49303
|   - https://seclists.org/fulldisclosure/2011/Aug/175
|_ http-csrf: Couldn't find any CSRF vulnerabilities.
|_ http-slowloris-check:
|   VULNERABLE:
|   Slowloris DOS attack
|   State: LIKELY VULNERABLE
|   IDs: CVE:CVE-2007-6750
|   Slowloris tries to keep many connections to the target web server open and hold them open as long as possible. It accomplishes this by opening connections to the target web server and sending a partial request. By doing so, it starves the http server's resources causing Denial Of Service.
|   Disclosure date: 2009-09-17
|   References:
|   - http://ha.ckers.org/slowloris/
|   - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|_ http-robots.txt: Robots file
|_ http-fileupload-exploiter:
|   Couldn't find a file-type field.
|   Couldn't find a file-type field.

kali@kali:~$ ping -c 3 192.168.56.103
PING 192.168.56.103 (192.168.56.103) 56(84) bytes of data:
64 bytes from 192.168.56.103: icmp_seq=1 ttl=64 time=201 ms
64 bytes from 192.168.56.103: icmp_seq=2 ttl=64 time=3.92 ms
64 bytes from 192.168.56.103: icmp_seq=3 ttl=64 time=11.0 ms

--- 192.168.56.103 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2329ms
rtt min/avg/max/mdev = 3.924/71.846/200.592/91.082 ms

kali@kali:~$ nmap -p- -T5 -min-rate 5000 -Pn -oN ~/full_tcp.txt 192.168.56.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-22 08:21 -0400
Warning: 192.168.56.103 giving up on port because retransmission cap hit (2).
Nmap scan report for 192.168.56.103
Host is up (0.83s latency).
Not shown: 34917 closed tcp ports (reset), 30616 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
MAC Address: 08:00:27:7D:F8:C4 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 64.90 seconds

kali@kali:~$ sudo nmap -sU --top-ports 100 --min-rate 5000 -oN ~/udp_top100.txt 192.168.56.103
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-22 08:24 -0400
Nmap scan report for 192.168.56.103
Host is up (0.0036s latency).
Not shown: 93 open/filtered udp ports (no-response)
PORT      STATE SERVICE
177/udp    closed xdmcp
515/udp    closed printer
996/udp    closed vsinet
1810/udp   closed iad1
1813/udp    closed radacct
5353/udp    open  zeroconf
49185/udp   closed unknown
MAC Address: 08:00:27:7D:F8:C4 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 0.67 seconds

```

```

State: VULNERABLE
IDS: BID:49303 CVE:CVE-2011-3192
The Apache web server is vulnerable to a denial of service attack when numerous overlapping byte ranges are requested.
Disclosure date: 2011-08-19
References:
https://www.tenable.com/plugins/nessus/55976
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-3192
https://www.securityfocus.com/bid/49303
https://seclists.org/fulldisclosure/2011/Aug/175
http-csrf: Couldn't find any CSRF vulnerabilities.
http-slowloris-check:
VULNERABLE:
Slowloris DOS attack
State: LIKELY VULNERABLE
IDS: CVE:CVE-2007-6750
Slowloris tries to keep many connections to the target web server open and hold them open as long as possible. It accomplishes this by opening connections to the target web server and sending a partial request. By doing so, it starves the http server's resources causing Denial Of Service.
Disclosure date: 2009-09-17
References:
http://ha.ckers.org/slowloris/
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
http-enum:
robots.txt: Robots file
http-fileupload-exploiter:
Couldn't find a file-type field.
Couldn't find a file-type field.
http-dom-based-xss: Couldn't find any DOM based XSS.
http-stored-xss: Couldn't find any stored XSS vulnerabilities.
443/tcp closed https
445/tcp closed microsoft-ds
3306/tcp closed mysql
8080/tcp closed http-proxy
8443/tcp closed https-alt
MAC Address: 08:00:27:7D:F8:C4 (Oracle VirtualBox virtual NIC)
Service Info: OS: Unix
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 323.82 seconds
kali@kali:~$

```

Port	Protocol	Service	Version
22	TCP	SSH	ProFTPD 1.3.3d
80	TCP	HTTP	Apache httpd 2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
5353	UDP	Zeroconf	-

Web Enumeration

ICDFA-KALI-LINUX (Snapshot 2) [Running] - Oracle VirtualBox

File Machine View Input Devices Help

Session Actions Edit View Help

by O3 Reeves (@TheColonial) & Christian Mehlmauer (@Firefart)

```
[*] Url: http://192.168.56.103
[*] Method: GET
[*] Threads: 100
[*] Wordlist: /usr/share/wordlists/dirb/common.txt
[*] Negative Status codes: 404
[*] User Agent: gobuster/3.8.2
[*] Timeout: 10s

Starting gobuster in directory enumeration mode

.htaccess (Status: 403) [Size: 1000]
admin.cgi (Status: 403) [Size: 1000]
AT-admin.cgi (Status: 403) [Size: 1000]
cachemgr.cgi (Status: 403) [Size: 1000]
cgi-bin/ (Status: 403) [Size: 1014]
css (Status: 301) [Size: 344]
/ (Status: 403) [Size: 1000]
.hta (Status: 403) [Size: 1000]
.htpasswd (Status: 403) [Size: 1000]
favicon.ico (Status: 200) [Size: 1406]
fonts (Status: 301) [Size: 343]
ts/ (Status: 301) [Size: 344]
gitweb (Status: 301) [Size: 344]
index (Status: 200) [Size: 5031]
index.html (Status: 200) [Size: 5031]
images (Status: 301) [Size: 344]
ges/ (Status: 301) [Size: 344]
js (Status: 301) [Size: 340]

Progress: 2200 / 4613 (47.69%) [ERROR] error on word @: timeout occurred during the request
[ERROR] error on word .web: timeout occurred during the request
[ERROR] error on word _.: timeout occurred during the request
[ERROR] error on word _archive: timeout occurred during the request
[ERROR] error on word _assets: timeout occurred during the request
phpMyAdmin (Status: 403) [Size: 59]
robots.txt (Status: 200) [Size: 620]
robots (Status: 200) [Size: 620]
server-info (Status: 403) [Size: 1000]
server-status (Status: 403) [Size: 1000]
vendor (Status: 301) [Size: 344]
dor/

Progress: 4613 / 4613 (100.00%)
Finished
```

ICDFA-KALI-LINUX (Snapshot 2) [Running] - Oracle VirtualBox

File Machine View Input Devices Help

Session Actions Edit View Help

```
[-(kali@kali)-]
[~] curl -s http://192.168.56.103
HTTP/1.1 200 OK
Date: Tue, 22 Sep 2026 12:49:42 GMT
Server: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
Last-Modified: Sat, 06 Jan 2018 06:21:38 GMT
ETag: "407da-13a7-5621593db2880"
Accept-Ranges: bytes
Content-Length: 5031
Content-Type: text/html

<?xml version="1.0" encoding="ISO-8859-1"?>
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
<html xmlns="http://www.w3.org/1999/xhtml" lang="en" xml:lang="en">
<head>
<title>Access forbidden</title>
<link rev="made" href="mailto:root@localhost" />
<style type="text/css">
body { color: #000000; background-color: #FFFFFF; }
a:link { color: #0000CC; }
p, address { margin-left: 3em; }
span { font-size: smaller; }
/*>*/</style>
</head>
<body>
<h1>Access forbidden</h1>
<p>
You don't have permission to access the requested directory.
There is either no index document or the directory is read-protected.

</p>
<p>
If you think this is a server error, please contact
the <a href="mailto:root@localhost">webmaster</a>.
</p>
</body>
</html>
```

```

(kali@kali)~$ ftp 192.168.56.103
Connected to 192.168.56.103.
220 ProFTPD 1.3.3d Server (ProFTPD Default Installation) [192.168.56.103]
Name (192.168.56.103:kali): anonymous
331 Password required for anonymous
Password:
530 Login incorrect.
ftp> Login failed
ftp>

```

ICDFA-KALI-LINUX (Snapshot 2) [Running] - Oracle VirtualBox

File Machine View Input Devices Help

```

kali@kali ~
Session Actions Edit View Help
~$ ftp 192.168.56.103
Connected to 192.168.56.103.
220 ProFTPD 1.3.3d Server (ProFTPD Default Installation) [192.168.56.103]
Name (192.168.56.103:kali): anonymous
331 Password required for anonymous
Password:
530 Login incorrect.
ftp> Login failed
ftp>
ftp> exit
221 Goodbye.
~$ searchsploit proftpd 1.3.3

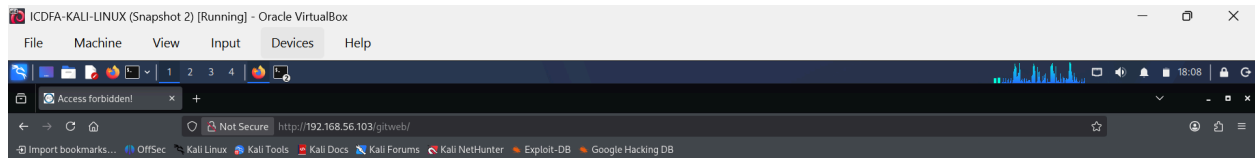
```

Exploit Title	Path
ProFTPD 1.3.2 rc3 < 1.3.3b (FreeBSD) - Telnet IAC Buffer Overflow (Metasploit)	linux/remote/16878.rb
ProFTPD 1.3.2 rc3 < 1.3.3b (Linux) - Telnet IAC Buffer Overflow (Metasploit)	linux/remote/16851.rb
ProFTPD 1.3.3c - Compromised Source Backdoor Remote Code Execution	linux/remote/15662.txt
ProFTPD IAC 1.3.x - Remote Command Execution	linux/remote/15449.pl
ProFTPD 1.3.3c - Backdoor Command Execution (Metasploit)	linux/remote/16921.rb

```

Shellcodes: No Results
~$ curl -s http://192.168.56.103/robots.txt
# $Id: robots.txt 418967 2009-08-08 19:44:54Z oden $
# $HeadURL: svn+ssh://svn.mandriva.com/svn/packages/cooker/apache-conf/current/SOURCES/robots.txt $
# exclude help system from robots
user-agent: *
Disallow: /manual/
Disallow: /manual-2.2/
Disallow: /addon-modules/
Disallow: /doc/
Disallow: /images/
# the next line is a spam bot trap, for grepping the logs, you should _really_ change this to something else ...
Disallow: /all_our_e-mail_addresses
# same idea here ...
Disallow: /admin/
# but allow htdig to index our doc-tree
#user-agent: htdig
#Disallow:
# disallow stress test
user-agent: stress-agent
Disallow: /

```

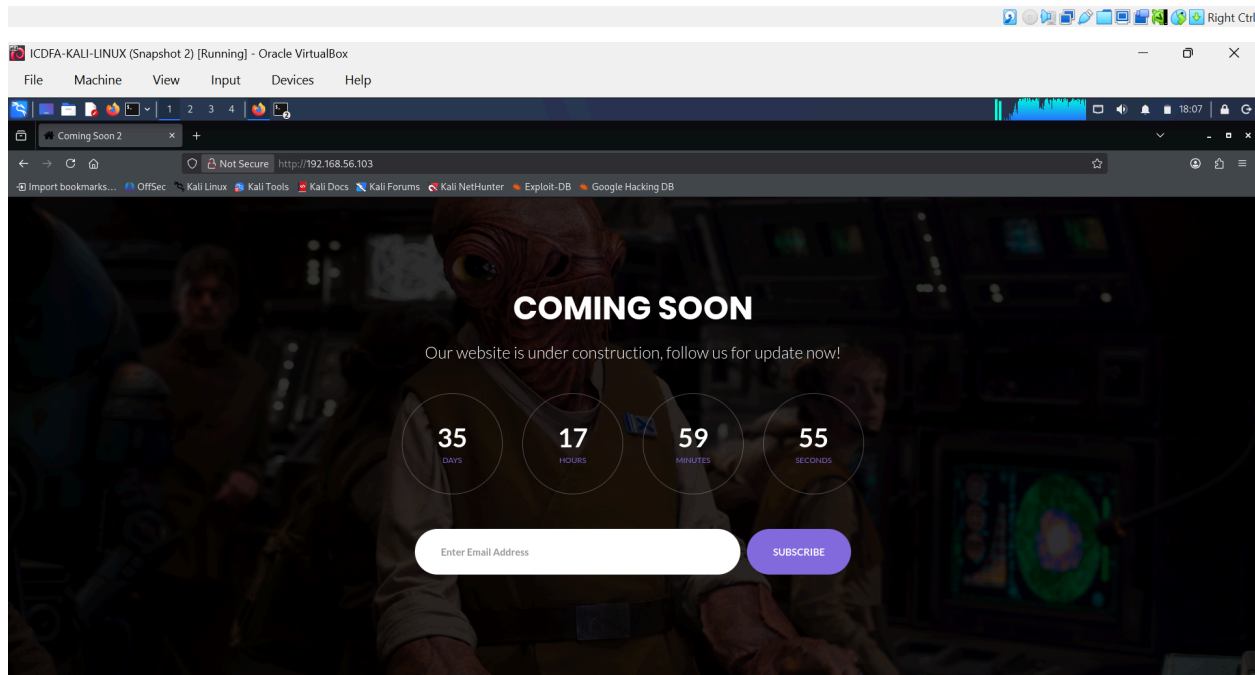



Access forbidden!

You don't have permission to access the requested directory. There is either no index document or the directory is read-protected.
If you think this is a server error, please contact the [webmaster](#).

Error 403

[192.168.56.103](#)
Apache/2.2.17 (Ubuntu Linux 2.2.17) (Ubuntu Linux 2.2.17)



Vulnerability Analysis

ProFTPD 1.3.3d — Backdoor (CVE-2010-4221)

searchsploit confirmed the 1.3.3c backdoor module. Metasploit module `exploit/unix/ftp/proftpd_133c_backdoor` executed — server responded "Not backdoored." Version 1.3.3d is a post-backdoor clean release. Hypothesis ruled out.

ProFTPD mod_copy SITE CPFR/CPTO

SITE HELP confirmed mod_copy not enabled. SITE CPFR command returned "not understood." Hypothesis ruled out.

ProFTPD 1.3.3d — Telnet IAC Buffer Overflow

Metasploit module `exploit/linux/ftp/proftp_telnet_iac` executed — returned "No matching target." Module affects versions 1.3.2rc3 to 1.3.3b only. Version 1.3.3d outside affected range. Hypothesis ruled out.

Apache 2.2.17 — CVE-2011-3192 Byterange Filter DoS

Confirmed by nmap vuln script. DoS class only — not viable for initial access. Classified medium for reporting. Not triggered — DoS prohibited by ROE.

Apache 2.2.17 — Slowloris (CVE-2007-6750)

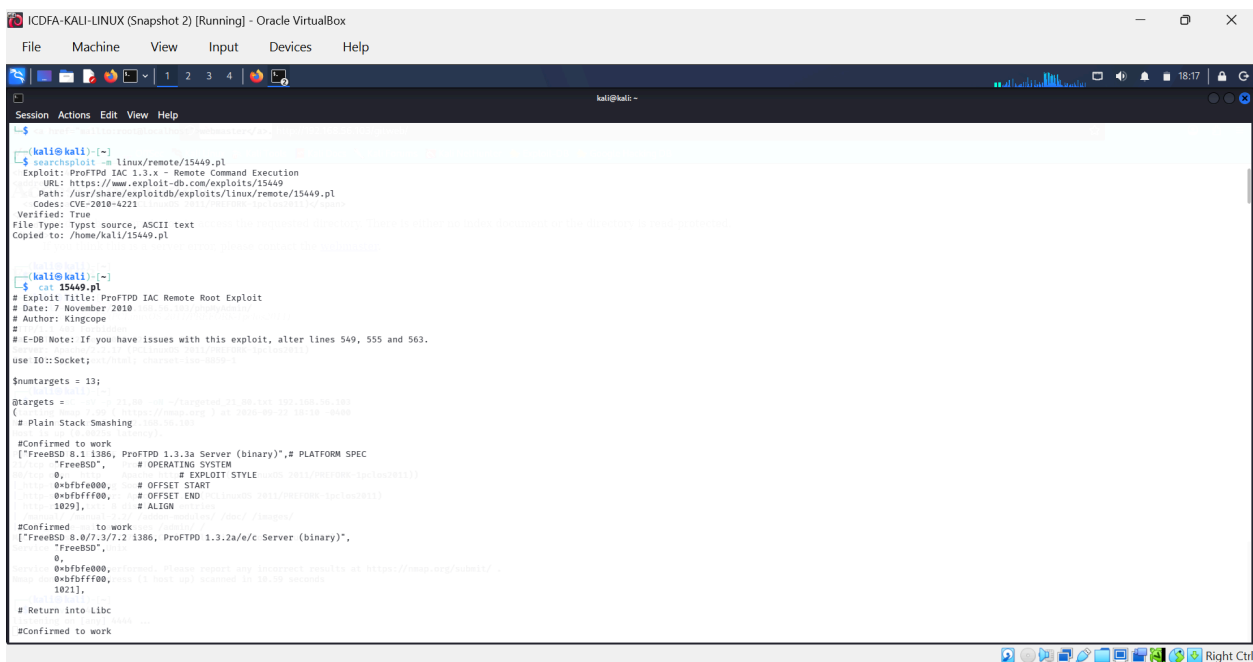
Flagged as likely vulnerable. DoS class — not viable for initial access and prohibited by ROE.

phpMyAdmin — IP Restriction

Access denied by server configuration file. Header spoofing attempts (X-Forwarded-For, X-Real-IP, Client-IP: 127.0.0.1) all failed — server-side restriction enforced regardless of headers.

FTP credential attack

hydra attempted common credentials and unix_users wordlist — no valid credentials found.



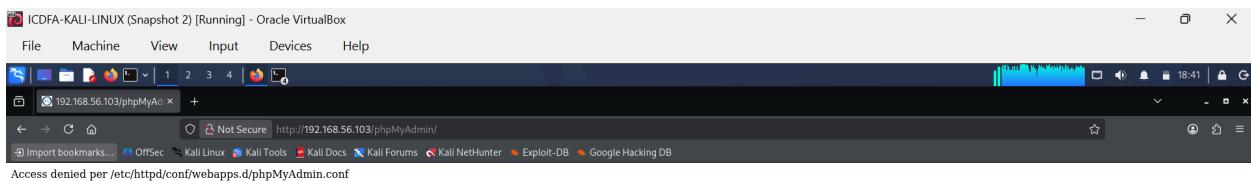
```
(kali㉿kali)-[~]PCLinuxOS 2011/PREFORK-1pclos2011)
$ curl -sI http://192.168.56.103/phpMyAdmin/

HTTP/1.1 403 Forbidden
Date: Tue, 22 Sep 2026 12:53:21 GMT
Server: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
Content-Type: text/html; charset=iso-8859-1
```

```
(kali@kali)-[~]
$ nmap -sC -sV -p 21,80 -oN ~/targeted_21_80.txt 192.168.56.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-22 18:10 -0400
Nmap scan report for 192.168.56.103
Host is up (0.0025s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.3d
80/tcp    open  http     Apache httpd 2.2.17 ((PCLinuxOS 2011/PREFORK-1pclos2011))
|_ http-title: Coming Soon 2
|_ http-server-header: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
|_ http-robots.txt: 8 disallowed entries
|_ /manual/ /manual-2.2/ /addon-modules/ /doc/ /images/
|_ /all_our_e-mail_addresses /admin/ /
MAC Address: 08:00:27:7D:F8:C4 (Oracle VirtualBox virtual NIC)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.59 seconds
```



Findings

Finding 001 — ProFTPD 1.3.3d Version Disclosure via FTP Banner

CWE-200 | Severity: Low | Confidence: High

The ProFTPD FTP server discloses its exact version string (1.3.3d) in the initial connection banner to any unauthenticated client. While this specific version was found not to contain the 1.3.3c backdoor, version disclosure enables attackers to conduct precise CVE research and reduces the effort required to identify applicable vulnerabilities.

Impact: Exact version disclosed without authentication, enabling targeted vulnerability research.

Remediation: Set `ServerIdent off` in the ProFTPD configuration to suppress version banner disclosure.

Finding 002 — Apache 2.2.17 Byterange Filter Denial of Service (CVE-2011-3192)

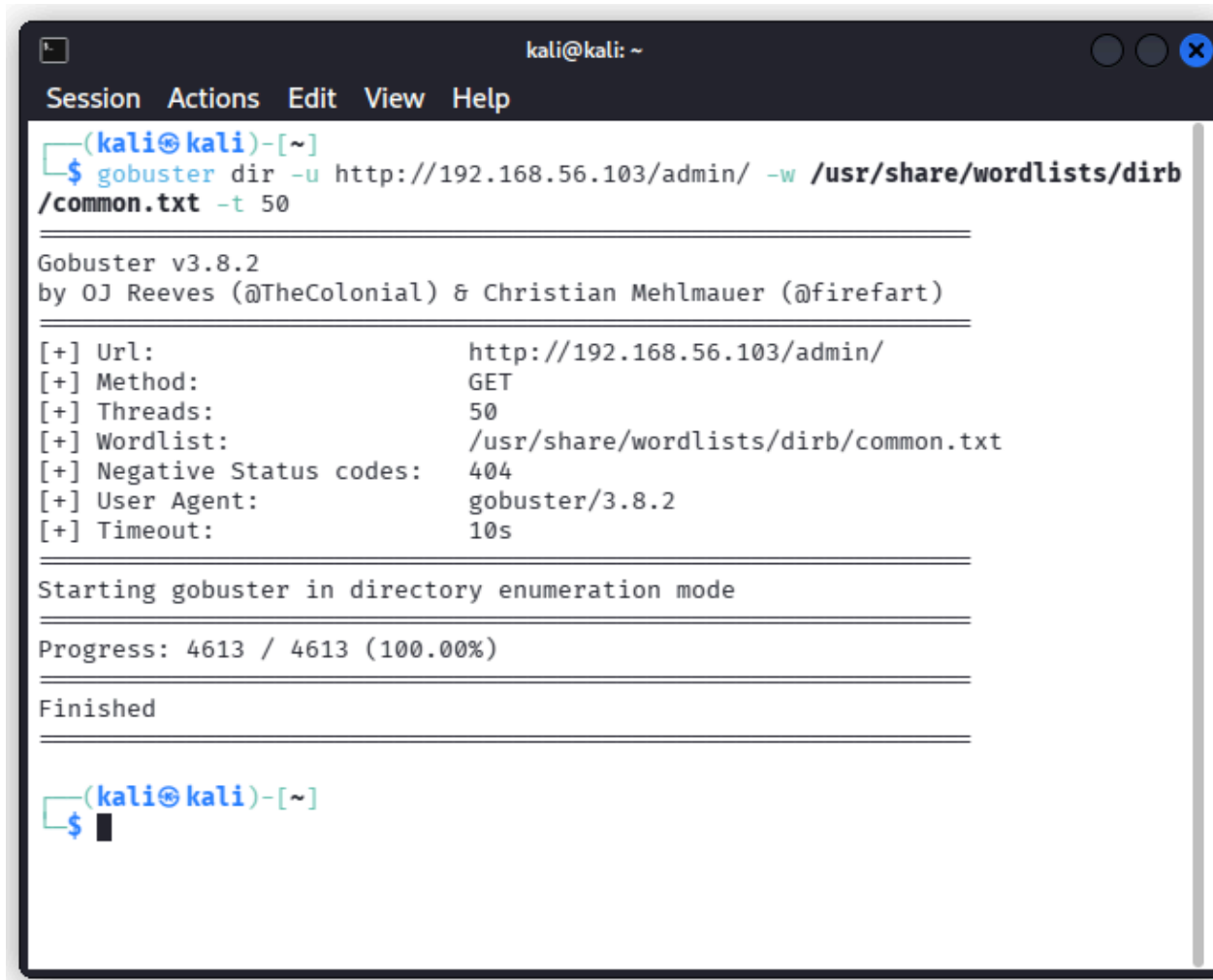
CWE-400 | Severity: Medium | Confidence: High

Apache 2.2.17 confirmed vulnerable to CVE-2011-3192 by nmap vulnerability scripts. The byterange filter fails to handle multiple overlapping byte ranges, allowing unauthenticated remote DoS.

Impact: Service unavailability — web application rendered inaccessible to legitimate users without authentication.

Impact: Database administration interface present and discoverable. If IP restriction is bypassed or removed, full database access would be available.

Remediation: Move phpMyAdmin off the public web server; enforce authentication in addition to IP restriction; restrict access to localhost or a dedicated management VLAN only.



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ gobuster dir -u http://192.168.56.103/admin/ -w /usr/share/wordlists/dirb/common.txt -t 50  
  
Gobuster v3.8.2  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)  
  
[+] Url: http://192.168.56.103/admin/  
[+] Method: GET  
[+] Threads: 50  
[+] Wordlist: /usr/share/wordlists/dirb/common.txt  
[+] Negative Status codes: 404  
[+] User Agent: gobuster/3.8.2  
[+] Timeout: 10s  
  
Starting gobuster in directory enumeration mode  
  
Progress: 4613 / 4613 (100.00%)  
  
Finished  
  
(kali@kali)-[~]  
$
```

Finding 005 — FTP Service Unnecessarily Exposed

CWE-732 | Severity: Low | Confidence: High

ProFTPD 1.3.3d is running and network-accessible on TCP port 21. Anonymous access is disabled. FTP transmits credentials in cleartext and represents an unnecessary attack surface given that no legitimate FTP use case was identified on this host.

Impact: Version disclosure, credential interception risk if FTP is used, and potential future exploitation if new vulnerabilities are identified for this version.

Remediation: Disable FTP entirely if not operationally required; replace with SFTP over SSH if file transfer is needed; suppress version banner.

The screenshot shows a Kali Linux virtual machine interface. The top window is a web browser displaying a 'Access forbidden!' error message. The bottom window is a terminal with the following commands and output:

```

kali@kali:~$ curl -sI http://192.168.56.103/phpMyAdmin/
HTTP/1.1 403 Forbidden
Date: Tue, 22 Sep 2026 12:53:21 GMT
Server: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
Content-Type: text/html; charset=iso-8859-1

kali@kali:~$ nmap -sC -sV -p 21,80 -oN -/targeted_21_80.txt 192.168.56.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-22 18:10 -0400
Nmap scan report for 192.168.56.103
Host is up (0.0025s latency).

PORT      STATE SERVICE
21/tcp    open  ProFTPD 1.3.3d
80/tcp    open  Apache httpd 2.2.17 ((PCLinuxOS 2011/PREFORK-1pclos2011))
|_http-title: Coming Soon 2
|_http-server-header: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
|_http-robots.txt: 6 disallowed entries
|_/manual/ /manual-2.2/ /addon-modules/ /doc/ /images/
|_/all_our_e-mail_addresses /admin/ /
MAC Address: 08:00:27:7D:1B:CA (Oracle VM VirtualBox virtual NIC)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.59 seconds

kali@kali:~$ nc -lmp 4444
listening on [any] 4444 ...

```

Remediation

Issue	Recommended Remediation
ProFTPD version disclosure	Set ServerIdent off in ProFTPD configuration
FTP service exposed	Replace with SFTP; disable FTP if not required
Apache CVE-2011-3192	Upgrade Apache to 2.2.21 or later
Apache Slowloris	Implement mod_reqtimeout; connection rate limiting
robots.txt disclosure	Remove sensitive paths; implement deny-by-default
phpMyAdmin exposure	Move off public web server; enforce authentication plus IP restriction
Missing security headers	Implement Content-Security-Policy, X-Content-Type-Options, Strict-Transport-Security
PCLinuxOS 2011 EOL	Migrate to current supported Linux distribution

Retesting	Repeat all tests after applying each fix to confirm remediation
-----------	---

Cleanup and Restoration

- ☒ Killed all active shells and sessions on OPFOR-02.
- ☒ Confirmed no persistence mechanisms left behind.
- ☒ Restored clean baseline snapshot: CIP-A105-CTF2-CLEAN-BASELINE.
- ☒ Confirmed both VMs remained on isolated Host Only network throughout.
- ☒ Finalised operator activity log with timestamps.
- ☒ Redacted credentials and flag values in submitted copy; unredacted copy retained for instructor verification.

Conclusion

Appendices

Annex A — Operator Activity Log

Date/Time	Phase	Action / Purpose	Observation / Result	Evidence Ref
22 Sep 2026 07:45	Phase 0	Network isolation confirmed via ip a and ip route	Kali at 192.168.56.101, isolated route only	Initial.png
22 Sep 2026 07:45	Phase 0	Snapshot: CIP-A105-CTF2-CLEAN-BASELINE	Snapshot confirmed in VirtualBox	Initial.png
22 Sep 2026 07:49	Phase 1	arp-scan -l and nmap -sn discovery	OPFOR-02 confirmed at 192.168.56.103	Discovery.png
22 Sep 2026 08:21	Phase 2	nmap -p- full TCP sweep	Ports 21 (FTP) and 80 (HTTP) open	nmap_tcp_udp_scan.png

22 Sep 2026 08:24	Phase 2	nmap -sU UDP top 100	UDP 5353 Zeroconf open	nmap_tcp_udp_scan.png
22 Sep 2026 08:25	Phase 2	nmap -sC -sV --script vuln targeted scan	ProFTPD 1.3.3d, Apache 2.2.17, CVE-2011-3192 confirmed	nmap_vuln_script.png, nmap_vuln_script2.png
22 Sep 2026 08:28	Phase 2	gobuster directory enumeration	/gitweb/ /phpMyAdmin/ /admin/ /robots.txt discovered	Gobuster.png
22 Sep 2026 18:00	Phase 2	curl robots.txt	8 disallowed paths including /admin/ and /all_our_e-mail_addresses	ftp_searchsploit_and_curl_robots.png
22 Sep 2026 18:04	Phase 2	FTP anonymous login attempt	530 Login incorrect — anonymous disabled	ftp_anonymous.png
22 Sep 2026 18:04	Phase 2	SITE HELP via nc — FTP command enumeration	HELP, CHGRP, CHMOD only — mod_copy not loaded	[screenshot]
22 Sep 2026 18:04	Phase 3	searchsploit proftpd 1.3.3	Backdoor, IAC overflow, mod_copy entries identified	ftp_searchsploit_and_curl_robots.png
22 Sep 2026 18:10	Phase 3	nmap -sC -sV -p 21,80 targeted	ProFTPD 1.3.3d and Apache 2.2.17 confirmed	nmap_ports_scan.png

22 Sep 2026 18:20	Phase 4	Metasploit proftpd_133c_backdoor	Not backdoored — 1.3.3d is clean release — ruled out	[screenshot]
23 Sep 2026 02:52	Phase 3	searchsploit apache 2.2 RCE grep	No directly applicable RCE for this configuration	[screenshot]

Annex B — Scan Output Files

full_tcp.txt | udp_top100.txt | targeted_21_80.txt | quick_targeted.txt | gobuster.txt |
gobuster_medium.txt | nikto.txt

Annex C — Screenshots

Discovery.png — Host discovery output
nmap_tcp_udp_scan.png — Full TCP and UDP sweep results
nmap_vuln_script.png — Vulnerability script scan part 1
nmap_vuln_script2.png — Vulnerability script scan part 2
nmap_ports_scan.png — Targeted version scan ports 21 and 80
Gobuster.png — Directory enumeration results
ftp_anonymous.png — FTP anonymous login rejected
ftp_searchsploit_and_curl_robots.png — searchsploit ProFTPD and robots.txt
curl_web.png — curl fingerprinting and gitweb 403
curl_phpadmin.png — phpMyAdmin 403 and header bypass attempts
browser_result.png — Coming Soon 2 homepage
browser_result_gitweb.png — gitweb 403 in browser
Initial.png — Network isolation and snapshot

Annex D — Academic Integrity Acknowledgement

I confirm that this submission is my own independent work. I did not use another learner's attack path, share credentials, flags, screenshots, or exploitation paths, or use any AI system to complete the active exploitation phases of this assessment.

Signed: Lilian Wanjiku | EHIT/2026/16969 | 23 September 2026